Загуглить противника: Threat Intelligence для начинающих

Редактируемый бриф и полный черновик выступления • 25 минут + отдельное время на вопросы

Спикер: [Имя, должность], [Название компании]. Исследование и проверка документации: 14 октября 2026 года. Исторический центральный кейс: кампании Luna Moth 2022 года. Материал не является описанием расследования компании спикера.

1. Концепция и редакторское решение

Доклад полезен студентам и начинающим аналитикам центра мониторинга безопасности — SOC. Главный вопрос: «Что делать с подозрительным адресом или файлом, если внешний сервис не дает однозначного ответа?» После выступления слушатель сможет выбрать источник под свой вопрос, прочитать отчет с учетом времени и ограничений, вернуться к внутренним событиям и записать вывод с конкретным следующим действием.

Сквозная схема: событие → вопрос → внешний источник → интерпретация → проверка внутри компании → решение. На экране она постепенно заполняется; интерфейсы появляются только в тех местах, где помогают ответить на вопрос.

			Два варианта центральной истории
Вариант	Завязка и маршрут	Сильная сторона	Цена для новичка
Luna Moth: «Программа настоящая. А поддержка?»	Учебное обращение: сотрудник сам позвонил по номеру из счёта о подписке; история жалоб на IP, отчет о файле/домене, затем проверка разрешенности удаленной сессии и передачи данных. Реальный контекст — опубликованные расследования Sygnia и Unit 42.	Объясняет пользу контекста даже при отсутствии вредоносного файла; естественно приводит к проверке поведения и hunting.	Нельзя обещать обнаружение группы по одному адресу. Подробный граф инфраструктуры исключаем.
3CX, март–апрель 2023: «Официальная программа делает неожиданное»	Подозрение вокруг настольного телефонного клиента; сравнение точных хешей и сетевых направлений с публичным исследованием; проверка версий, файлов и соединений внутри организации.	Очень ясный переход от опубликованных индикаторов к внутреннему поиску. Sophos публикует запросы по файлам, версиям и сетевым событиям.	Нужны объяснения компрометации поставщика и загрузки библиотек; историю жалоб AbuseIPDB придется вводить как вспомогательный, более слабый сигнал. [R4–R5]

Выбран Luna Moth, но центральная линия — проверка злоупотребления легитимным ПО, а не восстановление всего графа атакующего. Это сохраняет исходный интерес к кейсу и решает задачу новичка: понять, что внешняя оценка объекта сообщает о нашем событии, а что еще нужно проверить.

Что установлено о Luna Moth и что доступно

Sygnia описала ложные подписки, звонки и использование Zoho Assist для получения доступа; в отчете названы средства администрирования и передачи данных. Unit 42 описала расследованные в 2022 году атаки с хищением данных и последующим вымогательством без шифрования в этой

кампании. Свойства этой кампании нельзя переносить на все действия группы за все годы. Это чужие расследования, которые мы используем как внешний контекст. [R1–R2]

В исходной карточке SANS подтверждены название, авторы Noam Lifshitz и Oren Biderman, дата 31 января 2023 года и ссылка на PDF. Найден URL записи. Получить содержимое записи и PDF не удалось: запись не просмотрена, слайды не изучены. Поэтому конкретные переходы от IoC к инфраструктуре в этом выступлении не пересказываются. Его описание подтверждает замысел истории, но не доказательства отдельных связей. [R3]

Для одного исторического перехода используем только опубликованную Sygnia пару: maaays[.]xyz ↔ 192[.]236[.]194[.]2; в таблице ее роль обозначена как Exfiltration Server. Это связка из отчета 2022 года, а не проверка текущего DNS, владельца или активности адреса. Совпадение провайдера либо IP с другими объектами не доказывает единого оператора. [R1]

Уровни материала обозначаются явно: «учебная ситуация» — исходное обращение и вопросы к нашим журналам; «реальный опубликованный кейс» — факты исследователей; «гипотеза» — предполагаемое продолжение проверки. Результатов внутреннего расследования в черновике нет.

2. Исследованные выступления и приемы подачи

Ниже — редакторская оценка реально полученных материалов. Видео не просмотрены. Описания приемов — наши выводы о подаче, а не цитаты авторов.

Выступление, автор, год

Что получено и на чем построен рассказ

Что перенять

Что сократить для начинающих

Effective Threat Intel, Aaron Shelmire, SANS CTI Summit, 2017X

Авторский набор из 19 слайдов и его текст. От полезности TI для решения — к контексту и ограничениям совпадений по индикаторам.

Показать, как после обогащения меняется действие аналитика, а не только количество полей.

Статистику 2016 года и детали измерения эффективности детектов.

The Art of Pivoting — How You Can Discover More from Adversaries with Existing Information, Alexandre Dulaunoy, FIRST CTI, 2025X

Текст PDF, 22 слайда; программа FIRST подтверждает 23 апреля 2025 года. Аналогия связей → переходы по признакам → сопоставление нескольких признаков.X

Один понятный переход по связи; отдельно сказать, что связь еще не доказывает принадлежность.

Каталог favicon, DOM, заголовков, ключей и идентификаторов. В нашей истории достаточно домена, IP и времени.

Confidence in Chaos: Strategies for World-Class Security Operations, Kathryn Knerler, Carson Zimmerman, Black Hat Europe, 2022X

Текст PDF, 21 слайд. TI помещен в общий процесс SOC; внешние сведения дополняются внутренними данными и контекстом актива.

После внешнего отчета обязательно вернуться к вопросу «что произошло у нас?».

Все 11 стратегий SOC и полную архитектуру платформ.

Death to the IOC: What’s Next in Threat Intelligence, Bhavna Soman, Black Hat USA, 2019X

Текст PDF, 36 слайдов, и авторский разбор Microsoft. От чтения отчетов — к извлечению сущностей и связей, затем к защитным решениям.X

Превратить абзац отчета в небольшую схему «объект — действие — следующий вопрос».

Модели машинного обучения и их оценку. Провокационный заголовок не переносить в вывод о бесполезности IoC.

Luna Moth: A Practical Case of Threat Intelligence — From IoC to Unraveling an Attacker Infrastructure, Noam Lifshitz, Oren Biderman, SANS CTI Summit, 2023X

Только карточка и описание. Содержимое записи и PDF не получено. Заявленный сюжет — расширение от индикатора до инфраструктуры.X

Сам принцип расследовательской истории; содержательные приемы выступления оценить нельзя.

Непроверенные инфраструктурные переходы. Основу нашего кейса дают прочитанные отчеты R1–R2.

3. План на 25 минут

Время	Слайды	Задача блока
00:00–03:30	1–2	Учебное событие; наблюдаемый объект и IoC.
03:30–06:35	3–4	Роль внешних данных; вопрос, который определяет поиск.
06:35–10:40	5–6	AbuseIPDB и VirusTotal: чтение результата, время и пределы выводов.
10:40–12:10	7	Готовый отчет, новый анализ и раскрытие данных.
12:10–13:50	8	Необязательная демонстрация либо запасной экранный разбор.
13:50–17:20	9–10	Реальный Luna Moth; один исторический переход и пределы атрибуции.
17:20–20:45	11–12	

Возвращение в учебную инфраструктуру, проверка и запись вывода.

20:45–25:00

13–14

Проверяемая гипотеза hunting; алгоритм и возврат к началу.

Вопросы аудитории после 25-й минуты. В речи три коротких обращения к залу; на каждое закладывается пауза, без длинного обсуждения. Демонстрация уже входит в тайминг, а не добавляется сверху.

4. Полный текст устного выступления

Произносимая часть: 2699 слов, из них 140 — реплики демонстрации. Для плана заложены около 114 слов в минуту вне демонстрации, 1:40 на демонстрацию и короткие паузы. Это репетиционная оценка, а не измеренная длительность. Заголовки, тайминг и редакторские примечания не произносятся.

Слайд 1. Одно событие, с которого начнём ● 00:00–01:50

Представьте обычный рабочий день. Сотрудник сообщает: «Мне пришло письмо со счётом за подписку. Я сам позвонил по номеру из приложенного PDF. Мне предложили запустить программу удалённой поддержки. Теперь переживаю». В материалах этого учебного события есть ещё внешний сетевой адрес. Вот и всё, что мы пока знаем. Мы не знаем, кто говорил с сотрудником, что делал удалённый оператор и передавались ли какие-то файлы.

Я представляю [Название компании]. Сегодня мы попробуем пройти путь от такого сообщения до обоснованного следующего действия. Threat Intelligence — сведения об угрозах, которые мы оцениваем и используем для решений по защите. Возможно, перед нами мошенничество. Возможно, сотрудник неправильно понял вполне обычную поддержку. Именно эту неопределённость и нужно уменьшить.

Первый вопрос к залу: кто бы начал с поиска этого внешнего адреса в интернете? Поднимите руку. Это разумный первый шаг. А теперь мысленно добавьте к нему второй: что именно результат поиска сможет доказать?

За следующие двадцать пять минут мы разберём два доступных сервиса, научимся читать их ответы и сформулируем проверяемую гипотезу для поиска похожих событий. Главный результат сегодняшней встречи — привычка превращать найденную информацию в вопросы, на которые можно ответить данными. Давайте начнём с нашего адреса.

Слайд 2. Что мы ищем, когда ищем адрес ● 01:50–03:30

Внешний адрес — это наблюдаемый объект. Его можно записать, сравнить, поискать. Так же можно поступить с доменом, ссылкой из письма или именем программы. В Threat Intelligence для таких объектов часто используют слово observable. Здесь достаточно запомнить: это то, что мы увидели, а значение ещё предстоит выяснить.

Индикатор компрометации, или IoC, — признак, дающий основание подозревать нежелательное действие. Например, адрес, который исследователи связали с приёмом украденных данных в определённый период. Сам адрес остаётся наблюдаемым объектом; основание и условия делают его полезным индикатором. Но совпадение с ним ещё не доказывает компрометацию нашего компьютера. Программа удалённой поддержки тоже может помогать сотруднику, а может давать постороннему доступ.

Для сегодняшней истории полезны три группы артефактов. Сетевые: адреса, домены, ссылки. Файловые: сам файл, его имя и хеш, то есть отпечаток содержимого. Контекстные: письмо, телефон, идентификатор сеанса поддержки. Эти группы дополняют друг друга. Иногда телефон и текст письма объясняют больше, чем десяток сетевых адресов.

Поэтому сначала мы сохраняем исходное сообщение сотрудника и время события, а уже потом обогащаем отдельные объекты. Иначе легко получить много интересных сведений о совершенно другой истории. Наш следующий шаг — посмотреть, что известно об адресе, и аккуратно ограничить значение найденного ответа.

Слайд 3. Пять разных действий вместо одного слова • 03:30–05:15

Прежде чем открыть сервисы, договоримся о словах. Проверка репутации отвечает на узкий вопрос: что другие участники сообщали об этом объекте? Обогащение добавляет сведения: провайдер, даты наблюдений, тип файла, связанные объекты. Пока это ещё не объяснение нашего события.

Анализ Threat Intelligence начинается, когда мы связываем сведения с вопросом и оцениваем основания для вывода. Например: известен ли способ обмана, в котором после письма про подписку человек сам запускает удалённую поддержку? Насколько найденное описание похоже на наши обстоятельства? Какие альтернативы остаются?

Расследование инцидента отвечает уже про конкретный компьютер и конкретного сотрудника: был ли доступ, какие действия выполнялись, что затронуто. Центр мониторинга безопасности обычно называют SOC. Это команда, которая наблюдает события и разбирает подозрительные сигналы. Внешний отчёт помогает её работе, а конкретные действия нужно подтвердить собственными данными.

Наконец, поиск угроз, или hunting, проверяет, встречалось ли похожее поведение ещё где-то. Мы задаём гипотезу и ищем её следы в доступной истории событий, даже если отдельного предупреждения о них не было.

Все пять действий нужны. Ошибка возникает, когда между ними исчезают границы: «Адресу пожаловались, значит мы расследовали инцидент». Нет, мы получили одну подсказку. Теперь нужно понять её происхождение, время и отношение к нашему вопросу. Именно так будем читать первый сервис.

Слайд 4. Перед поиском — вопрос • 05:15–06:35

Вернёмся к учебному обращению. У нас есть внешний адрес, но нам нужно выяснить несколько разных вещей. Замечали ли с него нежелательную активность? Какая программа обращалась к нему? Кто разрешил эту программу запустить? На последний вопрос внешний сервис вообще не сможет ответить.

Выберем объект под каждый вопрос. Для истории IP подойдёт AbuseIPDB. Для конкретного файла нужен его хеш, лучше SHA-256: отпечаток именно этих байтов. По нему можно искать готовый отчёт VirusTotal. Имя файла такой точности не даёт: его легко изменить.

Если в письме была ссылка, различаем полный URL и домен. URL включает конкретный путь и иногда параметры. Отчёт о домене не описывает автоматически каждую его страницу. Сохраняем исходную ссылку внутри расследования, а перед внешним запросом отдельно проверяем, что допустимо раскрыть.

Запишем вопрос до открытия вкладки: «Что известно об этом объекте и как это поможет проверить событие?» Так мы получим понятную задачу для каждого источника. Начнём с истории сообщений об IP.

Слайд 5. AbuseIPDB: история сообщений и время • 06:35–08:35

AbuseIPDB собирает сообщения о нежелательной активности с сетевых адресов. Читаем даты, период, источники и категории. Сколько пользователей сообщало об адресе? Есть ли содержательные комментарии? Речь о переборе паролей, нежелательной почте или сканировании?

Количество сообщений не равно количеству атак. Повторы могут поступать от одного участника, а разные пользователи не обязательно представляют независимые организации. В API количество сообщений относится к выбранному окну. В интерфейсе записываем тот период, который действительно показан.

Если жалобы касаются сканирования, они помогают понять историю адреса. Они ещё не подтверждают, что именно с него управляли компьютером сотрудника. Отсутствие жалоб означает отсутствие видимых сообщений в этом периоде. Новая или мало наблюдаемая активность могла не попасть в базу.

Оценка уверенности сервиса учитывает сообщения и их возраст. Её нельзя превращать в вероятность нашего инцидента. Даже максимум шкалы не доказывает, что любое соединение с адресом является атакой.

Время особенно важно. Система DNS сопоставляет имя домена с адресом сервера. Сегодняшний ответ может отличаться от ответа в момент события. Сам IP мог перейти другому арендатору; на общем хостинге размещаются разные сайты.

Поэтому историческую связь проверяем по собственным записям или сведениям с понятным временем наблюдения. Название провайдера и страна помогают описать объект, но не определяют намерения пользователя. Проверяем эти детали там, где они меняют вывод.

Полезная заметка: «За такой-то период есть сообщения таких-то типов; отношение к нашему событию ещё проверяется». Теперь перейдём от истории адреса к сведениям о других объектах.

Редакторское основание, не произносить: R6–R7; ссылки в разделе 9.

Слайд 6. VirusTotal: учимся читать отчёт • 08:35–10:40

В VirusTotal важно выбрать нужный тип объекта. Для IP и домена смотрим сведения и связи сетевого объекта. Для URL — отчёт о конкретной ссылке. Для файла ищем хеш и читаем файловый отчёт. Вердикты сервисов проверки ссылок об IP или домене не означают, что антивирус проверил файл. Затем обязательно смотрим дату анализа.

Второй вопрос к залу: если все показанные движки оставили файл без обнаружения, готовы ли вы разрешить ему удалённо управлять рабочим компьютером? Подумайте несколько секунд. Отчёт полезен, но разрешение зависит ещё от происхождения файла, запроса сотрудника и правил компании.

Число обнаружений не является вероятностью атаки. Один результат может быть ложным срабатыванием. Много результатов заслуживают внимания, но их названия и причины тоже нужно читать. Отметка undetected означает, что конкретное средство не дало обнаружения или не выразило мнение при этой проверке. Harmless — отдельное мнение о невредоносности. Таймаут означает, что результат не получен. Ни отсутствие детектов, ни ошибка анализа не гарантируют безопасность.

Посмотрите дальше: какой тип файла указан, кто его подписал, какие действия наблюдались при анализе, есть ли связанные домены, адреса и другие файлы. Поведение может объяснить, что программа умеет делать. Связи могут подсказать следующий объект для проверки.

При этом отчёт о возможностях программы не отвечает, кто запустил её у нашего сотрудника и кто был по другую сторону сеанса. Перед использованием этих сведений обсудим, какие данные допустимо передавать внешнему сервису.

Редакторское основание, не произносить: R8–R10, R12; ссылки в разделе 9.

Слайд 7. Что можно отправлять во внешний сервис • 10:40–12:10

Очень соблазнительно скопировать в поиск всё, что есть в сообщении сотрудника. Но ссылка может содержать персональный идентификатор или токен доступа. В файле могут быть клиентские данные. Даже внутреннее имя ресурса иногда раскрывает лишнее. Поэтому сначала действуют правила компании и условия используемого сервиса.

Документация VirusTotal прямо предупреждает об анализе и включении в общий набор данных сообщества индикаторов, переданных или запрошенных через веб-интерфейс либо API. Поэтому поиск существующего отчёта не нужно считать гарантией конфиденциальности.

Поиск по хешу и загрузка самого файла — разные действия. В первом случае мы ищем известный отпечаток, во втором передаём содержимое. Но это различие не отменяет необходимости оценить, какие сведения раскрывает наш запрос и разрешён ли такой способ работы.

Для публичной демонстрации возьмём уже опубликованный объект. В реальном расследовании конфиденциальные файлы и ссылки остаются в разрешённом контуре. Если внешний запрос не допускается, используем внутренние средства или согласованный процесс анализа.

Перед запросом остановитесь на секунду: публичен ли объект, нет ли в нём секрета и допускают ли правила компании такой способ проверки?

Редакторское основание, не произносить: R11; ссылки в разделе 9.

Слайд 8. Демонстрация: один публичный объект ● 12:10–13:50

Теперь можно открыть заранее подготовленные публичные отчёты. На демонстрацию отведена минута сорок. Если сервис недоступен, используем подготовленный снимок с источником и датой. Если снимка нет, разберём поля без показа результатов.

Для показа берём опубликованный исторический IP из исследования Sygnia, 192[.]236[.]194[.]2. Это отдельный демонстрационный объект, который не относится к внешнему адресу учебного компьютера.

В AbuseIPDB смотрим период, даты, категории и происхождение жалоб, если они доступны. Текущая оценка не доказывает состояние адреса в прошлом.

В отчёте VirusTotal проверяем тип объекта и даты, затем доступные связи. У каждой спрашиваем: когда и каким способом она установлена? Переход по ссылке сам по себе не делает соседний объект доказанным участником атаки. Если отчёт не открыт, мы не изображаем его содержимое.

По одному адресу мы не устанавливаем автора действий. Цель демонстрации — показать порядок проверки источников и ограничений. Теперь обсудим, зачем в нашей истории понадобилась эта публикация.

Редакторское основание, не произносить: R1; результаты карточек не получены; ссылки в разделе 9.

Слайд 9. Реальный кейс как источник вопроса ● 13:50–15:40

В июле две тысячи двадцать второго года Sygnia опубликовала исследование Luna Moth. PDF со счётом побуждал человека позвонить. Под предлогом отмены подписки его приглашали в Zoho Assist, затем устанавливали Atera для удалённого администрирования. Средства передачи файлов, включая Rclone, использовали для выноса данных. Это легитимные продукты: решающим было их использование посторонним оператором.

В ноябре Unit 42 опубликовала результаты своих расследований: в описанной кампании крали данные и вымогали деньги без шифрования. Callback phishing здесь означает фишинг, при котором жертву побуждают позвонить. Эти расследования принадлежат исследователям, к [Название компании] они не относятся.

Что мы берём из опубликованного материала? Проверяемую возможность: внешне обычная поддержка может оказаться частью цепочки обмана. Теперь для нашего события важнее происхождение сеанса и последующие действия, чем одно название приложения.

Но сходство отдельных деталей не даёт права назвать нашего собеседника Luna Moth. Письмо про подписку, звонок и удалённая поддержка помогают выбрать направление проверки. Они не доказывают автора действий, принадлежность к группе или к конкретной кампании.

Рабочая заметка должна отделять факты события от внешнего контекста: сотрудник сообщил одно; публичное исследование описывает другое; мы проверяем возможную связь через такие-то данные. Это простое разделение защищает от незаметного превращения предположения в факт.

Мы используем чужое расследование как источник вопросов. У нас ещё нет собственного ответа, происходила ли похожая цепочка на компьютере сотрудника.

Редакторское основание, не произносить: R1–R2; ссылки в разделе 9.

Слайд 10. Историческая связь и контекст действий • 15:40–17:20

В отчёте Sygnia две тысячи двадцать второго года есть историческая связка maaays[.]xyz и 192[.]236[.]194[.]2 в разделе Exfiltration Server. Это сведения публикации; сегодняшний адрес домена и текущий владелец здесь не установлены.

Представим, что найденный файл действительно относится к известному продукту удалённой поддержки. Подпись выглядит ожидаемой, тип файла понятен, массовых обнаружений нет. У нас появилась полезная информация: возможно, сотрудник запустил обычный инструмент. Но исходный вопрос всё ещё открыт.

Легитимность инструмента не означает, что его использование разрешено. Ключевое различие находится в контексте. Кто попросил запустить программу? Был ли запрос на помощь? Узнал ли сотрудник собеседника? Как был установлен контакт? Есть ли подтверждённая заявка и известный оператор? Для этого нужно вернуться к письму, звонку и обстоятельствам запуска.

Получается полезная смена фокуса. Мы начали с вопроса «плохой ли адрес?», а теперь спрашиваем: «на каких основаниях этому человеку предоставили доступ и что он сделал?» Первый вопрос помог собрать контекст. Второй приближает нас к проверке события.

То же относится к связям из сервисов. Соседство объектов может объясняться общим хостингом. Нужно выяснить время и характер связи. Исторический адрес помогает выбрать направление проверки, но не устанавливает автора действий в нашей истории.

Редакторское основание, не произносить: R1, R9; ссылки в разделе 9.

Слайд 11. Что проверять внутри компании • 17:20–19:25

Внешний контекст помог нам уточнить вопросы. Теперь нужно восстановить последовательность внутри компании. Начинаем с сотрудника: когда пришло письмо, когда был звонок, откуда взята программа, какие действия предложил собеседник. Сохраняем доступные материалы так, чтобы не потерять время и источник каждого факта.

Затем смотрим, какие технические данные вообще собираются. Защитное средство на компьютере может записывать запуск программ и часть их действий. Такой класс средств часто называют EDR. Сетевая история может показать обращения и объём переданных данных, если организация её собирает. Журналы самого сервиса поддержки могут уточнить сеанс и участника. Сопоставляем записи по устройству, времени, пользователю и идентификатору процесса или сеанса, если он доступен. Спрашиваем: какая программа установила соединение и есть ли следы передачи файлов? Запрос DNS ещё не означает соединение, а исходящий трафик сам по себе не доказывает кражу данных.

Не будем заранее придумывать записи, которых у нас нет. Отсутствующий журнал отличается от журнала, в котором событие действительно искали и не нашли. А запись о запуске программы

отличается от записи о передаче конкретного файла. Каждый источник отвечает на свой набор вопросов.

Если события собраны в общей системе поиска — SIEM, — сопоставлять их удобнее. Полнота всё равно зависит от охвата и срока хранения.

В итоге мы сможем перечислить подтверждённые действия и оставшиеся пробелы. Даже если вывод пока ограничен, это уже полезный результат: станет ясно, что проверить дальше и на каком основании принимать решение о реагировании. Прежде чем искать похожее поведение, нужно понятно записать результат нашей проверки.

Слайд 12. Как записать результат проверки • 19:25–20:45

Сохраняйте источник и дату просмотра рядом с выводом. Сервисы обновляются, отчёты меняются, ссылки пропадают. Коллеге понадобится понять основания вашего решения. Отдельно запишите факт, гипотезу, ограничения и следующий шаг.

Результат удобно описывать словами, которые можно проверить. Например: «Найдено такое-то поведение, согласование пока не подтверждено». Или: «В доступных данных последовательность не обнаружена; часть периода не покрыта». Это шаблоны формулировок: результатов внутренней проверки в нашем учебном примере ещё нет.

Если проверка дала новый сетевой адрес или хеш, возвращаемся к обогащению. Но каждый следующий переход должен отвечать вопросу расследования. Иначе можно долго переходить между связанными объектами и так и не узнать, что произошло с сотрудником.

Когда основания достаточны, команда действует по своему процессу реагирования. Когда их мало, фиксирует пробел и выбирает следующий способ проверки. Threat Intelligence полезна в обоих случаях: она помогает поставить вопрос и объяснить ограничение ответа. Теперь применим этот подход к поиску похожего поведения в прошлом.

Слайд 13. От расследования к проверяемому поиску • 20:45–23:20

Третий вопрос к залу: если в наших данных нет передачи файлов, можем ли мы сказать, что передачи не было? Дайте себе несколько секунд. Ответ зависит от того, записывали ли источники такие действия и сохранилась ли нужная история.

Попробуем сформулировать гипотезу аккуратно: в выбранном прошлом периоде могло происходить неразрешённое использование удалённой поддержки, после которого выполнялась передача файлов. В этой формулировке есть поведение и последовательность. Её можно проверить доступными данными.

Для учебного упражнения выберем последние четырнадцать дней. Это наше условие, а не универсальное правило и не характеристика опубликованного кейса. В настоящей работе окно зависит от времени события, предполагаемой длительности активности и срока хранения нужных источников. Если история доступна только частично, ограничение должно попасть в вывод.

Сначала определяем, какие средства удалённой поддержки встречаются в среде. Затем ищем запуск или сеансы, которые можем наблюдать. После них проверяем доступные следы передачи файлов. Допустимый интервал между действиями выбираем по устройству источников и задаче; волшебной минуты, подходящей всем, здесь нет.

Сопоставляем найденное с заявками поддержки, известными операторами и словами сотрудников. Обычная передача документа при согласованной помощи может выглядеть похоже на подозрительную цепочку. Поэтому совпадение условий поиска становится кандидатом для проверки.

Перед поиском полезно проверить покрытие: какие компьютеры присутствуют, каких нет, доступны ли нужные события за все четырнадцать дней. Затем для каждого кандидата собираем короткую последовательность: запуск или сеанс поддержки, последующее наблюдаемое действие, подтверждение разрешённого использования либо открытый вопрос.

Так мы заранее понимаем, что будет подтверждением, что ослабит предположение и какие данные могут отсутствовать. Хорошая гипотеза позволяет получить полезный отрицательный результат: в проверенном охвате мы не обнаружили нужной последовательности. Она также показывает, где этот результат ограничен. Первый конкретный шаг: запросить список запусков средств удалённой поддержки на рабочих станциях за доступные четырнадцать дней. По кандидатам проверить согласование и последующие действия. Теперь вернёмся к началу.

Слайд 14. Возвращаемся к сотруднику • 23:20–25:00

Сотрудник получил письмо со счётом за подписку, сам позвонил по номеру из PDF и запустил удалённую поддержку. Появился внешний сетевой адрес. В начале доклада это легко превращалось в задачу «найти плохой адрес». Теперь у нас есть более точный порядок действий.

Сохраняем исходные обстоятельства и время. Проверяем репутацию адреса, читая историю жалоб и её ограничения. По доступным файлам, доменам и ссылкам изучаем отчёты, даты, поведение и связи. Помним, что внешние проверки не разрешают использование инструмента и не гарантируют его безопасность.

Публичное исследование даёт нам направление: проверить, не использовали ли поддержку для неразрешённых действий. Собственные данные должны показать, что происходило в конкретном сеансе. А для поиска в прошлом у нас есть проверяемая гипотеза: удалённая поддержка, затем передача файлов, выбранный период и обязательная проверка контекста.

Мы не объявили учебное событие атакой и не установили противника. Зато каждый следующий шаг стал понятнее, а каждый будущий вывод сможет опираться на источник и условия проверки.

Если после выступления вы будете иначе читать хотя бы один отчёт — смотреть дату, происхождение данных и связь с вашим вопросом, — это уже практический результат. Начните с одного объекта, одного вопроса и одного проверяемого следующего действия. Спасибо.

5. Бриф 14 слайдов

Слайды не являются отдельным рассказом: они поддерживают речь из раздела 4. Указанные комментарии — акцент, а не дополнительный текст поверх хронометража. На схемах учебные части подписаны «Учебная ситуация», реальные — названием исследователя и годом. На титуле добавить [Название компании]; логотипы сервисов не использовать как знак партнерства.

1. Программа настоящая. А поддержка? ● 00:00–01:50

Мысль: даже простое обращение содержит неопределенность. **Экран:** три короткие реплики сотрудника: письмо о подписке → сам позвонил по номеру из счета → запустил удаленную поддержку. Внешний адрес — отдельная карточка без значения и оценки; подпись «Учебная ситуация». **Комментарий:** мы знаем сообщение сотрудника, но не знаем действия оператора. Первый вопрос залу — с чего начать. **Переход:** «Что именно мы сейчас собираемся искать?»

2. Адрес — наблюдение. IoC — признак с контекстом и основанием ● 01:50–03:30

Мысль: объект не доказывает компрометацию. **Экран:** три группы: сеть — IP/домен/URL; файл — SHA-256; контекст — письмо/номер/сеанс. Под ними пример: разрешенная и неразрешенная сессии одного инструмента. **Комментарий:** не все имена файлов и адреса автоматически становятся IoC. **Переход:** «Чем внешний поиск поможет работе аналитика?»

3. Внешние данные меняют следующий вопрос ● 03:30–05:15

Мысль: репутация, обогащение, анализ TI, расследование и hunting выполняют разные задачи. **Экран:** короткая цепочка: оценки → сведения → объяснение → проверка события → поиск гипотезы в истории. **Комментарий:** определять через действие, без отдельной лекции о терминах. **Переход:** «Перед поисковой строкой запишем вопрос».

4. Один объект — один проверяемый вопрос ● 05:15–06:35

Мысль: источник выбирается под вопрос. **Экран:** IP → история сообщений; SHA-256 → точный файл; домен/URL → объект нужного уровня; локальные журналы → процесс и действия. **Комментарий:** SHA-256 — отпечаток байтов, URL включает конкретный путь, домен его не заменяет. **Переход:** «Начнем с истории адреса».

5. AbuseIPDB: что сообщали об адресе? ● 06:35–08:35

Мысль: важны содержание, период и происхождение сообщений. **Экран:** схема полей «период / дата / категория / репортеры / оценка сервиса», без нарисованных результатов. **Комментарий:** количество сообщений не равно количеству атак; confidence не является вероятностью нашего инцидента. [R6–R7] **Переход:** «Теперь проверим другой объект и другой тип свидетельства».

6. VirusTotal: что известно именно об этом объекте? ● 08:35–10:40

Мысль: тип объекта, дата, вердикты и связи важнее одного счетчика. **Экран:** четыре карточки IP / domain / URL / file; определения malicious, undetected, harmless; строка «доля детектов ≠ вероятность». **Комментарий:** IP не файл, URL не весь домен. Второй вопрос залу — можно ли закрыть событие при отсутствии детектов. [R8–R10, R12] **Переход:** «Прежде чем вводить значение, проверим, что раскрывает запрос».

7. Готовый отчет, запрос, загрузка ● 10:40–12:10

Мысль: чтение готового отчета и передача содержимого — разные действия, но внешний запрос тоже раскрывает данные. **Экран:** hash/report; Upload; Reanalyze; короткая выдержка смысла актуального предупреждения VT, своими словами. **Комментарий:** приватные файлы, ссылки и

токены — в разрешенном контуре. Не обещать приватность произвольного lookup. [R11] **Переход:** «Для демонстрации возьмем уже опубликованный исторический объект».

8. Два источника — два вопроса • 12:10–13:50

Мысль: отчет надо читать как свидетельство с ограничениями. **Экран:** подготовленные карточки/скриншоты либо таблица Sygnia; большая подпись «Исторический объект из отчета 2022; к учебному хосту не привязан». **Комментарий:** сценарий раздела 6; не обещать видимые поля и не подставлять scores. **Переход:** «Почему этот реальный кейс меняет направление проверки?»

9. Luna Moth: привычные инструменты в цепочке обмана • 13:50–15:40

Мысль: назначение действий раскрывается через последовательность. **Экран:** счет → звонок → удаленная поддержка → дальнейшие действия → передача данных; подписи Sygnia / Unit 42, 2022. **Комментарий:** это опубликованные расследования исследователей; описанная кампания не определяет все действия группы. [R1–R2] **Переход:** «Какие связи можно взять из публикации и где остановиться?»

10. Нашли связь — проверяем время и основание • 15:40–17:20

Мысль: связь помогает проверке, но не устанавливает автора атаки. **Экран:** домен maaays[.]xyz ↔ IP 192[.]236[.]194[.]2, пунктир к надписи «роль в отчете 2022». Рядом три проверки: источник / время / характер связи. **Комментарий:** таблица исследователя не является текущим DNS; общий хостинг не доказывает общий контроль. [R1, R9] **Переход:** «Теперь возвращаемся к учебному сотруднику».

11. Что произошло у нас? • 17:20–19:25

Мысль: внутренние источники отвечают на вопрос о действиях. **Экран:** почта и человек → устройство/процесс → сессия поддержки → сеть/передача; под каждым «что можем подтвердить». Результаты не рисовать. **Комментарий:** кратко объяснить EDR; DNS уже введён ранее; факт соединения не равен краже. **Переход:** «Как записать вывод, когда часть данных еще отсутствует?»

12. Вывод, который можно проверить • 19:25–20:45

Мысль: факт, гипотеза и следующий шаг записываются отдельно. **Экран:** событие / внешнее свидетельство / внутренняя проверка / пробел / действие. Пример с пометкой «Учебная запись; проверка не выполнена». **Комментарий:** не объявлять учебное событие атакой. **Переход:** «Из этого вопроса можно сделать поиск в истории».

13. Hunting начинается с гипотезы • 20:45–23:20

Мысль: ищем возможное неразрешенное поведение в доступном охвате. **Экран:** гипотеза «удаленная поддержка → передача файлов»; окно «14 дней — условие упражнения»; проверить согласование и полноту данных. **Комментарий:** третий вопрос залу — что значит отсутствие находок. Показать подтверждение, альтернативное объяснение и ограничения отрицательного результата. **Переход:** «Что мы теперь сделаем с исходным обращением?»

14. Объект → вопрос → источник → проверка → действие • 23:20–25:00

Мысль: слушатель уносит порядок работы. **Экран:** та же схема, что в начале, и краткий шаблон заметки. **Комментарий:** вернуться к сотруднику; цель — обоснованный следующий шаг, имя группировки не требуется. **Переход:** завершить речь, затем открыть отдельное время на вопросы.

6. Необязательная демонстрация — 1 минута 40 секунд

Цель: показать, как один исторический объект порождает разные вопросы к двум источникам. Объекты: IP 192.236.194.2 и домен maaays.xyz из публичного отчета Sygnia. Их текущие карточки инструментом исследования получить не удалось. Числа жалоб, оценка AbuseIPDB и вердикты VT не зафиксированы и не предполагаются. Ссылки ниже — маршруты для проверки спикером, а не подтверждение доступности готового отчета.

	Подготовка: заранее открыть AbuseIPDB IP и VirusTotal domain. Убедиться, что отчеты доступны, сохранить нужные скриншоты с датой и видимым периодом. Не открывать сам домен как сайт, не скачивать образцы, не выбирать Upload, Scan или Reanalyze. Использовать только заведомо публичные исторические объекты.

Отрезок

Действие и реплика

0:00–0:15

Показать источник пары. «Это объект из опубликованного кейса 2022 года. Он не является адресом из нашего учебного обращения».

0:15–0:50

AbuseIPDB: указать период жалоб, даты, разных репортеров и категории, если они видны. «Отвечаем на вопрос об истории сообщений об активности с адреса. Мы не устанавливаем по ним, что сделал наш сотрудник». Читать только фактически видимые сведения. При пустом отчете: «В этом окне нет видимых сообщений; это не сертификат безопасности».

0:50–1:20

VT: назвать тип объекта, показать дату анализа, определения вердиктов и отношения, если доступны. «Домен и адрес из публикации надо сопоставлять по времени. Текущий отчет не восстанавливает автоматически события 2022 года». При отсутствии отношений не обещать их найти.

1:20–1:40

Вернуть схему расследования. «Следующий шаг — проверить внутри компании, какой процесс обращался к какому домену и когда. Внешний отчет дает вопрос, локальные события — ответ».

Запасной вариант со скриншотами: три заранее сохраненных кадра — (А) строка таблицы Sygnia с доменом, IP и ролью, (Б) область AbuseIPDB с периодом и датами, (В) тип объекта, дата и вердикты VT. Подписи: «Историческая публикация 2022» на А, «Снимок интерфейса: [дата, время, часовой пояс]» на Б–В. Обвести поля, не делать число детектов центром кадра. Снимки Б–В предстоит подготовить спикеру: в этом исследовании их содержимое недоступно.

Если обе карточки недоступны на репетиции, запасной разбор выполняется по кадру А и таблице значений полей из раздела 8. Сказать: «Сегодня читаем структуру отчета, его актуальные результаты у нас отсутствуют». Не подставлять вымышленные оценки. Без демо те же 100 секунд занять

упражнением: сформулировать два вопроса к источникам и один — к внутренним журналам. Новый независимый IP либо EICAR для этого сюжета не требуется.

7. Пять вероятных вопросов аудитории

Сколько детектов достаточно, чтобы признать файл вредоносным? Универсального порога нет. Смотрим, кто и что обнаружил, когда, как ведет себя файл и почему оказался на этом компьютере. Одного сильного сигнала бывает достаточно для приоритетной проверки; число само по себе вывод не заменяет.

Если в обоих сервисах пусто, можно закрыть событие? Нет. Внешних данных может не быть, а программа может быть легитимной. Решение принимаем по событию: кто разрешил доступ, что запускалось и что было передано.

Можно сразу заблокировать все адреса из старого отчета? Сначала проверить период, актуальную принадлежность и побочные последствия. Исторический IP мог сменить владельца или обслуживать много клиентов. При активной угрозе действуем по принятому процессу реагирования и имеющимся доказательствам.

Как понять, что это именно Luna Moth? По одному IP, инструменту либо похожему письму — никак. Для нашей задачи достаточно проверить несанкционированный доступ и возможную передачу данных. Атрибуция требует нескольких согласованных источников и самостоятельного обоснования.

Можно ли автоматизировать эти проверки в SOC? Да, через подходящие API и условия использования. Нужно сохранять тип объекта, даты, источник, период и ограничения, а не только score. Запросы к внешнему сервису также передают данные; лицензирование и правила обработки проверяются до внедрения. В докладе API не используется.

8. Памятка начинающему аналитику

Алгоритм проверки

Зафиксировать событие. Время и часовой пояс, компьютер, пользователь, процесс, направление соединения, источник журнала. Записать, что действительно наблюдалось: запрос DNS, попытка соединения, успешная сессия, сохранение файла или запуск — это разные события.

Выделить объект и вопрос. IP — история активности и сеть; домен — назначение и связи во времени; URL — конкретная страница и переходы; SHA-256 — точный файл. Домен, URL, IP и хеш не взаимозаменяемы.

Проверить допустимость внешнего запроса. Не передавать внутренние документы, персональные данные, приватные адреса страниц и токены. Наличие готового отчета не делает новый запрос гарантированно конфиденциальным. Сохранить полный оригинальный URL внутри расследования; не уничтожать значимые параметры при обезличивании внешнего запроса.

Выбрать источник. IP: AbuseIPDB — сообщения об активности с адреса; VT — объект инфраструктуры и его связи. Хеш: VT — существующий отчет конкретного файла. Домен/URL: VT — отчет правильного уровня. Публичный исследовательский отчет — роль объекта в известном кейсе и ее основания.

Прочитать содержание и время. Кто сообщил, что наблюдал, когда, в каком периоде? Какие вердикты получены, какие проверки результата не дали? Дата публикации, дата анализа, дата жалобы и время нашего события — разные даты.

Проверить объяснения. Ложное срабатывание; легитимный инструмент; общий хостинг; смена адреса/владельца; событие до появления внешнего отчета. Согласованные сигналы усиливают приоритет, но два сервиса могут повторять один исходный источник.

Вернуться внутрь. Проверить процесс, пользователя, согласованный канал поддержки, DNS/прокси/сетевые события, запуск и передачу файлов. Сопоставить события по устройству и времени, по идентификатору процесса/сессии — когда он есть. Запрос DNS не равен передаче данных, объем исходящего трафика не раскрывает его содержимое.

Записать вывод и действие. Отдельно факт, внешнее свидетельство, гипотезу, степень уверенности с основанием, пробелы и следующий шаг. Передать результат по процедуре команды; блокировка, изоляция либо закрытие должны иметь объяснение.

Как читать ключевые поля

Сервис / поле	Что означает	Что из него не следует
AbuseIPDB: totalReports	Количество сообщений в окне maxAgeInDays для CHECK API. В интерфейсе записываем реально видимый период.	Столько же разных атак или независимых организаций.
AbuseIPDB: numDistinctUsers, lastReportedAt	Разные пользователи-репортеры; время последнего сообщения.	Доказанная независимость источников или время нашего инцидента.
AbuseIPDB: abuseConfidenceScore	Оценка сервиса 0–100, учитывающая сообщения и их возраст.	Измеренная вероятность вредоносности нашего соединения. Не утверждать, что смена окна CHECK обязательно пересчитывает score.
VT: malicious, suspicious	Поставщик счел объект вредоносным или подозрительным.	Процент вероятности атаки из доли таких результатов.
VT: undetected, harmless	В первом случае поставщик не дает мнения/детекта; во втором считает объект невредоносным.	Гарантированная безопасность объекта или разрешенность его использования.
VT: timeout, failure, type-unsupported	Результат не получен или анализ этого типа не поддержан.	Отрицательная проверка на вредоносность.
VT: дата анализа и отношения	Когда анализировали объект; какие связи наблюдали в доступных данных.	Полная история объекта либо доказательство одного владельца всех связанных сущностей.

Основания определений: [R6–R12]. Таблица предназначена для чтения, не содержит результатов проверки конкретного индикатора.

Шаблон записи результата

Событие: [время с часовым поясом; устройство; пользователь; процесс; источник]. Объект: [тип и точное значение]. Вопрос: [что выясняем]. Внешние данные: [ссылка; дата получения и дата анализа/жалобы; период; содержание; ограничения]. Внутренняя проверка: [запрос/источник и фактический результат, либо «не выполнена»]. Вывод: [что подтверждено; что предполагается; уверенность и почему]. Пробелы: [чего не видно]. Следующий шаг: [действие; ответственный; срок по процессу команды].

Учебный пример записи без выдуманных результатов: «Сотрудник сообщил: после письма он сам позвонил по номеру из счёта и запустил удалённую поддержку. Разрешенность сессии не установлена. Внешняя репутация файла не отвечает на этот вопрос. Гипотеза: поддержка могла быть несанкционированной. Проверить обращение в службу поддержки, локальные события запуска и сетевую активность; результаты пока не получены». Это гипотеза, а не доказанная компрометация и не атрибуция Luna Moth.

9. Источники и подтверждаемые утверждения

Все ссылки проверялись 14 октября 2026 года. «Прочитан текст» означает доступный текст страницы или PDF; не означает просмотра видео либо воспроизведения чужого расследования. Текущие оценки конкретных IP/доменов, количество жалоб и число детектов не получены.

ID

Первоисточник / состояние доступа

Что подтверждает

R1

Sygnia — Luna Moth: The Threat Actors Behind Recent False Subscription Scams, Oren Biderman, Tomer Lahiyani, Noam Lifshitz, Ori Porag; первоначальная публикация 1 июля 2022; доступный текст прочитанX

Ложные подписки, удаленная поддержка, легитимные инструменты; роль и историческая пара maaays[.]xyz / 192[.]236[.]194[.]2. В доступной таблице есть более поздние дополнения 2022 года: ее не называем неизменным снимком на 1 июля.

R2

Unit 42 — Threat Assessment: Luna Moth Callback Phishing Campaign, Kristopher Russo, 21 ноября 2022; текст прочитанX

Расследованные атаки 2022 года: callback phishing, злоупотребление легитимным ПО, хищение и вымогательство без шифрования; пределы атрибуции.

R3

SANS — Luna Moth: A Practical Case…, Noam Lifshitz, Oren Biderman, 31 января 2023; описание прочитаноX

Авторство, дата и заявленная тема исходного выступления. Содержание видео и PDF не подтверждено.

R4

Sophos — 3CX users under DLL-sideloading attack, 2023, обновление 6 апреля; текст прочитанX

Компрометированные версии клиента, файлы, сетевые индикаторы и примеры внутренних запросов; пригодность альтернативного кейса.

R5

Mandiant — 3CX Software Supply Chain Compromise, 20 апреля 2023; текст прочитанX

Реальность компрометации цепочки поставки; дополнительная сложность ее причин для вводного сюжета.

R6

AbuseIPDB APIv2 — CHECK endpoint; официальная документация прочитанаX

Типы IP, окно maxAgeInDays, totalReports, отдельные отчеты и даты.

R7

AbuseIPDB FAQ и Bulk Checker Tutorial; прочитаныX

Модель confidence и старение сообщений; разные репортеры, последняя жалоба.

R8

VirusTotal — Analysis object; прочитанX

Категории результатов и статусы анализа; undetected не равен harmless, ошибки не являются подтверждением безопасности.

R9

VT — IP object и Domain object; прочитаныX

Типы объектов, даты, сетевой контекст и отношения; различие анализа IP/домена и файла.

R10

VT — Files, Get file report, URL object; прочитаныX

Точный файловый объект, поиск готового отчета по хешу; отдельный отчет URL и дата анализа.

R11

VT — Searching и Upload a file; прочитаныX

Готовый отчет отличается от повторной отправки материала; актуальное предупреждение о включении переданных и запрошенных IoC в доступный сообществу набор данных.

R12

VT Intelligence Introduction; прочитанX

Возможность ложных срабатываний и необходимость дополнительной оценки.

R13

Четыре выступления со ссылками в разделе 2; слайды/авторский текст прочитаны

Редакторская основа: контекст → связи → действие; внутренние данные как часть работы SOC.

Классификация наблюдаемых объектов, алгоритм проверки, учебные события, гипотеза hunting и шаблон вывода — собственный учебный синтез. Отдельные трактовки «совпадение не равно атрибуции» и «нет внешних записей не равно безопасно» — аналитические выводы из ограничений источников, а не обещанные результаты сервисов.

Urlscan не включен: для выбранной истории два основных сервиса уже отвечают на нужные вопросы. Автоматизация, платные функции, API-квоты и полный граф инфраструктуры не нужны для цели 25-минутного выступления.

10. Проверка и репетиция

Факты реального кейса отделены от учебной ситуации; чужое расследование названо; текущие показатели отсутствуют; точная инфраструктурная методика недоступного SANS не выдумана. Каждый инструмент отвечает на свой вопрос, а финальное решение опирается на проверку внутри компании. Проверка одного IP не названа hunting.

Перед выступлением заменить данные спикера и компании; сохранить скриншоты либо выбрать предусмотренный разбор без интерфейса. Два прочтения с секундомером: первое — в рабочем темпе, второе — с паузами и переключением экранов. Проверить отметки 06:35, 12:10, 17:20 и 20:45. Плановый темп и объем — оценка, фактическая длительность устанавливается репетицией.

Если превышение больше минуты, сократить объяснение полей и один пример отношений, сохранив возврат к внутренним журналам и hunting. Если речь заканчивается раньше, расширить обсуждение трех вопросов залу; не добавлять еще один сервис. Вопросы после доклада в эти 25 минут не входят.